

以程序架构探索 移动应用安全的发展历程



- WHOAMI ? ? ?
- 残废
- 四叶草安全安全服务部成员，雁行安全团队成员
- 主攻渗透测试，web安全，拥有数百个企业安服实战经验
- 曾多次出现在国内安全顶尖会议
- 多次在甲方安全应急响应中心获得奖项
- Mail : chaihao@seclover.com



- 从互联网到移动应用
- 登陆流程
- 身份认证
- 支付安全
- 用户交互
- 存储机制
- 数据安全
- 客户端缺陷
- 风险控制

从互联网到移动互联——宏观角度

- 互联网到物联网
- 移动设备智能化
- 移动应用多元化
- 移动安全事件的频发
- 移动应用安全检测基准
- 恐怖的移动应用
- 有意识的构建移动应用安全标准体系

测试者眼中的移动应用——微观角度

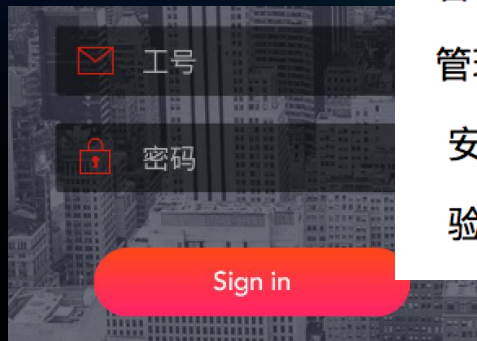


? ? ?



登陆流程

- 单因子→多因子→复杂因子→时效因子

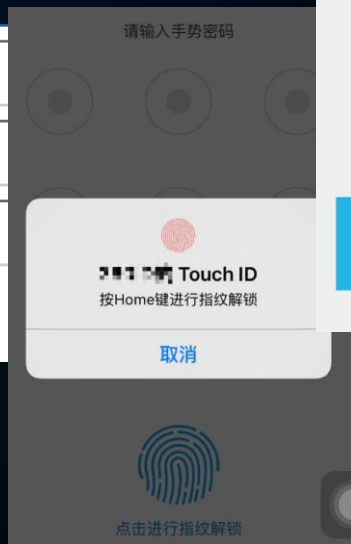


管理账号:

管理密码:

安全码:

验证码: 9113



身份识别

- What you know
- What you have
- What are you
- Can i know ?
- Can i have ?
- Can i be you ?



手机验证

身份认证

- 单一身份标识

- 多重身份检查

Request

Raw Params Headers Hex

```
GET /T user money LoginId Servlet?login_id=1 HTTP/1.1
Connection: close
Accept-Encoding: gzip
User-Agent: okhttp/3.3.1
```

Response

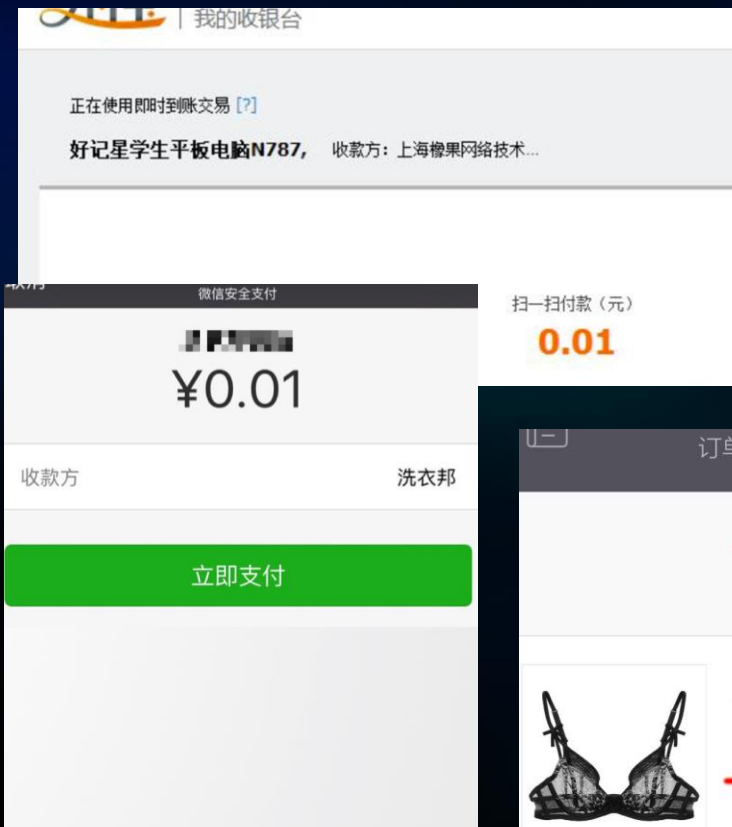
Raw Headers Hex

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=utf-8
Date: Thu, 16 Mar 2017 08:53:33 GMT
Connection: close
Content-Length: 222

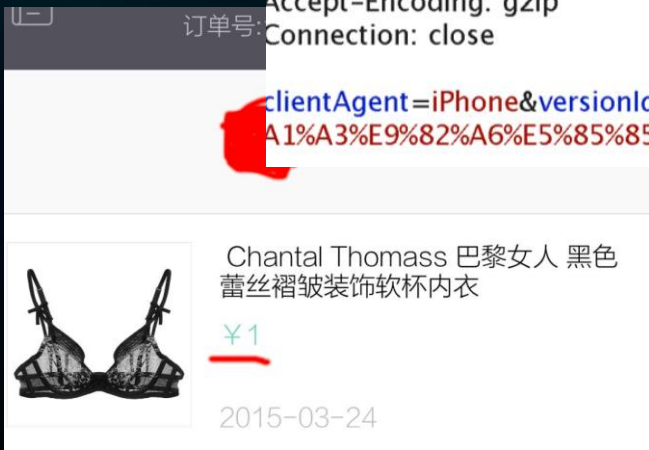
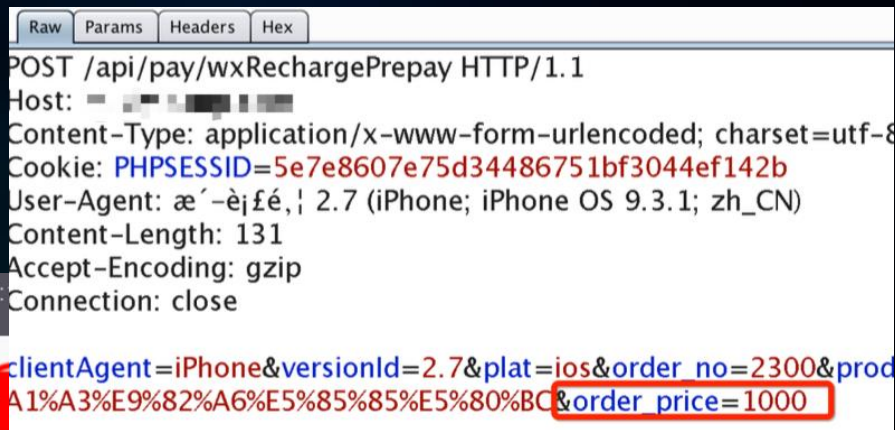
{"message": "用户余额查询成功", "weixin": "0", "data": {"t_user_money": {"id": "1", "login_id": "1", "same": "0", "money": "8.88", "zhifubao": "0", "riskang": "0", "kahao": "0", "pay_password": "0", "pay_status": "1", "weixin": "0"}}, "code": "200"}
```

Raw Params Headers Hex

```
GET
/Cashier/wap_fxy?extern_token=RZ12b2sXT...VbfowILw59mobilegwRZ12&
appidToken=x5%2B...iMQJ1WCBozkMpGdAp7YMCOSo6PzEqioy07z1R7XWgEB&trade_no=
201703172100...27089901&return_url=https%3A%2F%2Fds.alipay.com%2Fi%2Findex
.htm%3FiframeSrc%3Dalipays%53A%252F%252Fplatformapi%252Fstartapp%253FappId%253
D10000009&app_name=alipay&logon_id=&partner=&biz_type=&biz_sub_type= HTTP/1.1
Host: ...
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Cookie: JSESSIONID=56...J3F5E38A73A6A2;
ALIPAYJSESSIONID=RZ12b2sXT...TaVbfowILw59mobilegwRZ12;
ALIPAYJSESSIONID.sig=JDF-RFu...BdNUGYJzFdXI8rg4DE08sajno;
cna=Sy1NES5z1tgCAQF...;
devKeySet={"appidToken":"x5...iMQJ1WCBozkMpGdAp7YMCOSo6PzEqioy07z1R7XWg
EB"}; session.cookieNameId=ALIPAYJSESSIONID; zone=RZ12B;
_uat_collina=1489384...621929802;
_umdata=E2AE901...EEDD6EB2F6C0C920015D598D29D167B149F3A92053F01A
F23F99F50CD43A...CC187E36C60363F328B4;
cna=ueVIEUfy300CnX...; credibleMobileSendTime=-1; ctuMobileSendTime=-1;
mobileSendTime=-1; riskCredibleMobileSendTime=-1; riskMobileAccoutSendTime=-1;
riskMobileBankSendTime=-1; riskMobileCreditSendTime=-1;
riskOriginalAccountMobileSendTime=-1;
Content-Length: 21
```

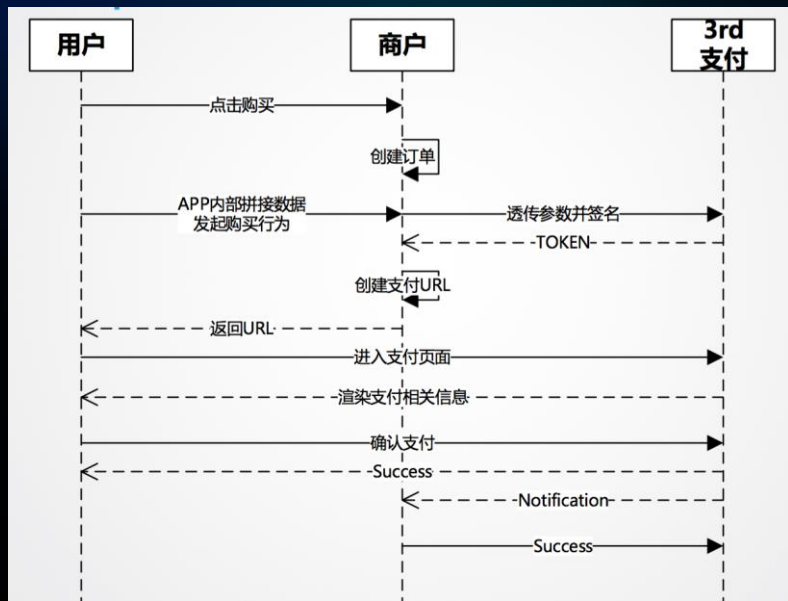


支付业务

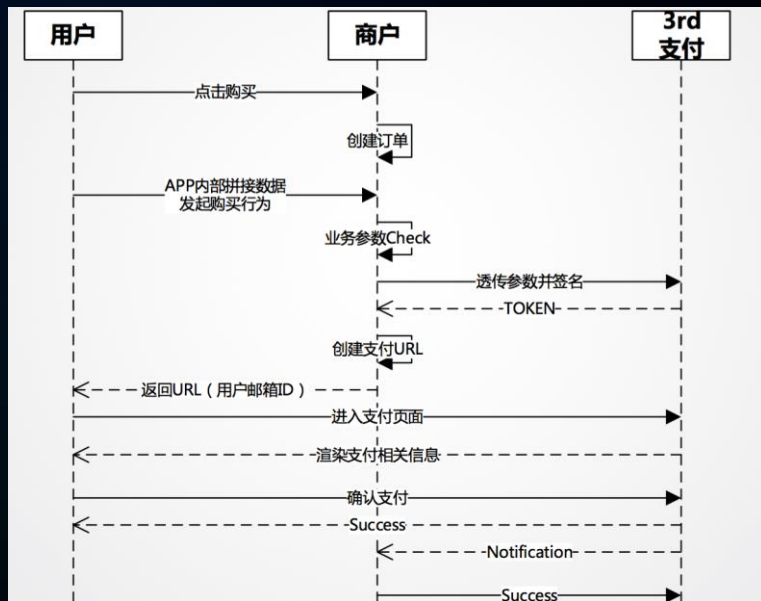


支付业务安全

• 常规支付模型

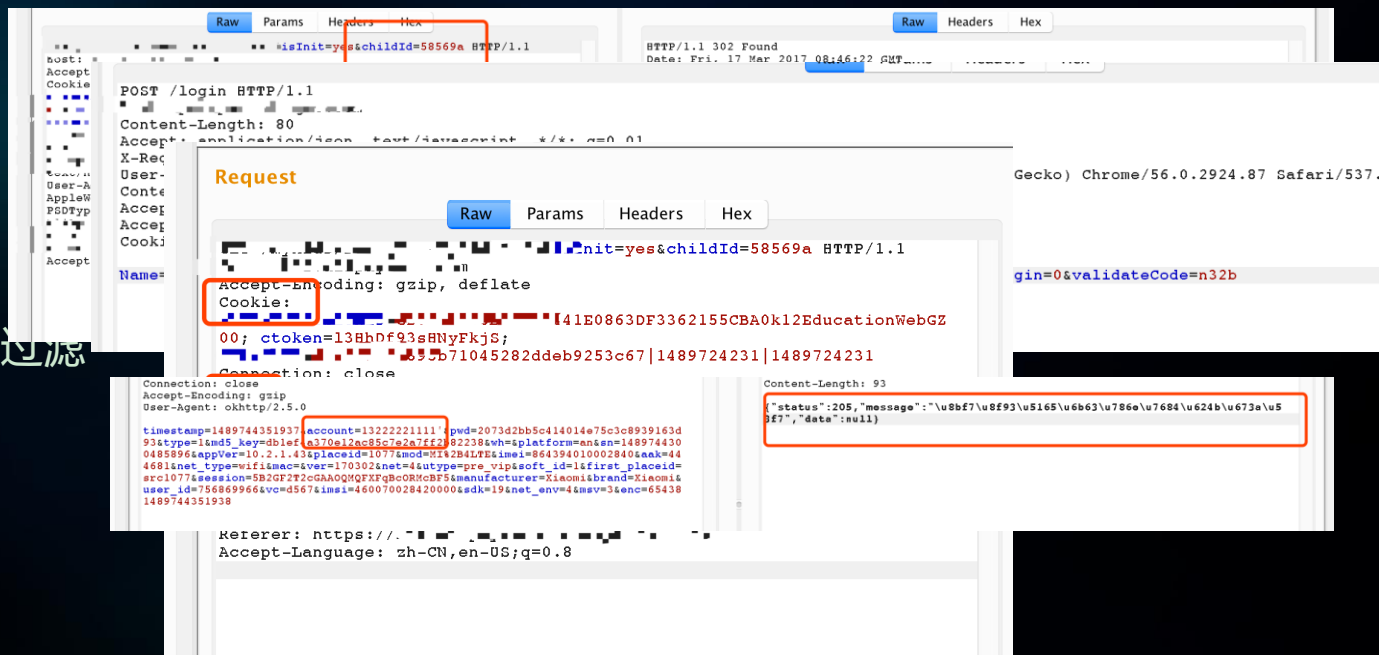


• 低风险支付模型



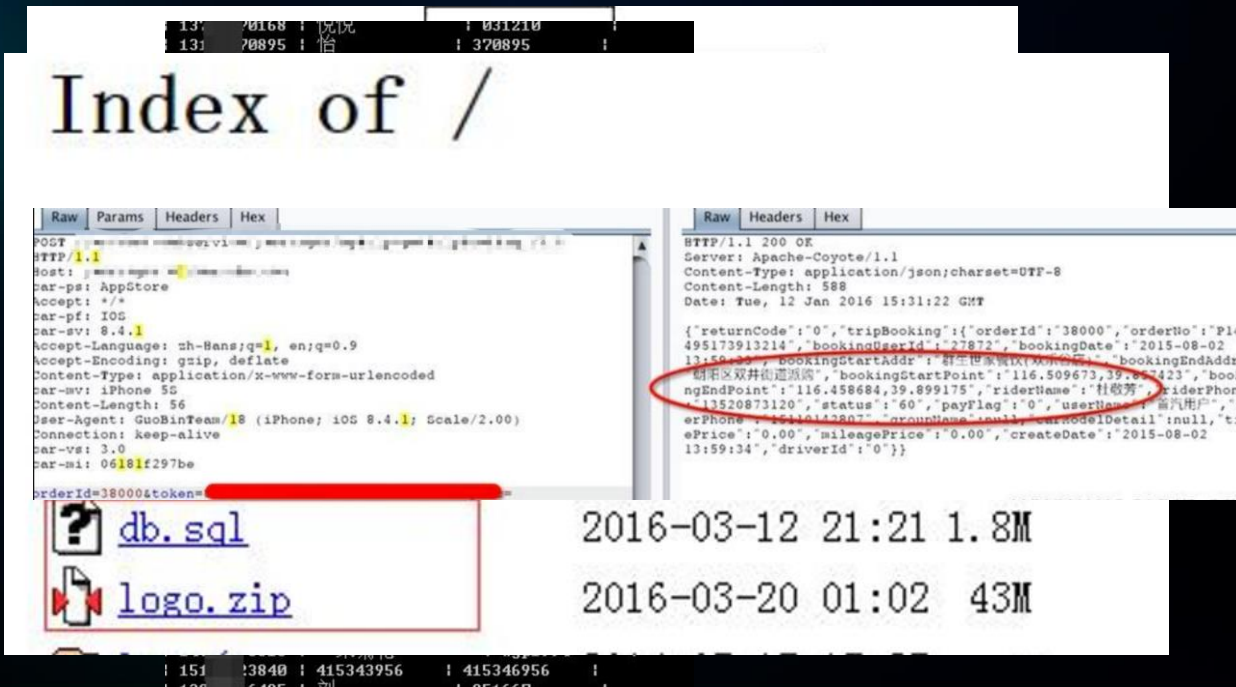
用户交互

- 参数数据类型控制
- 数据传输加密
- 安全认证机制
- 用户输入内容检测及过滤
- 用户权限控制
- 参数值的加密



数据安全

- 数据对称算法加密
- 敏感内容加密
- 权限未明确建立
- 数据备份 / 迁移
- 数据访问控制权限



存储安全

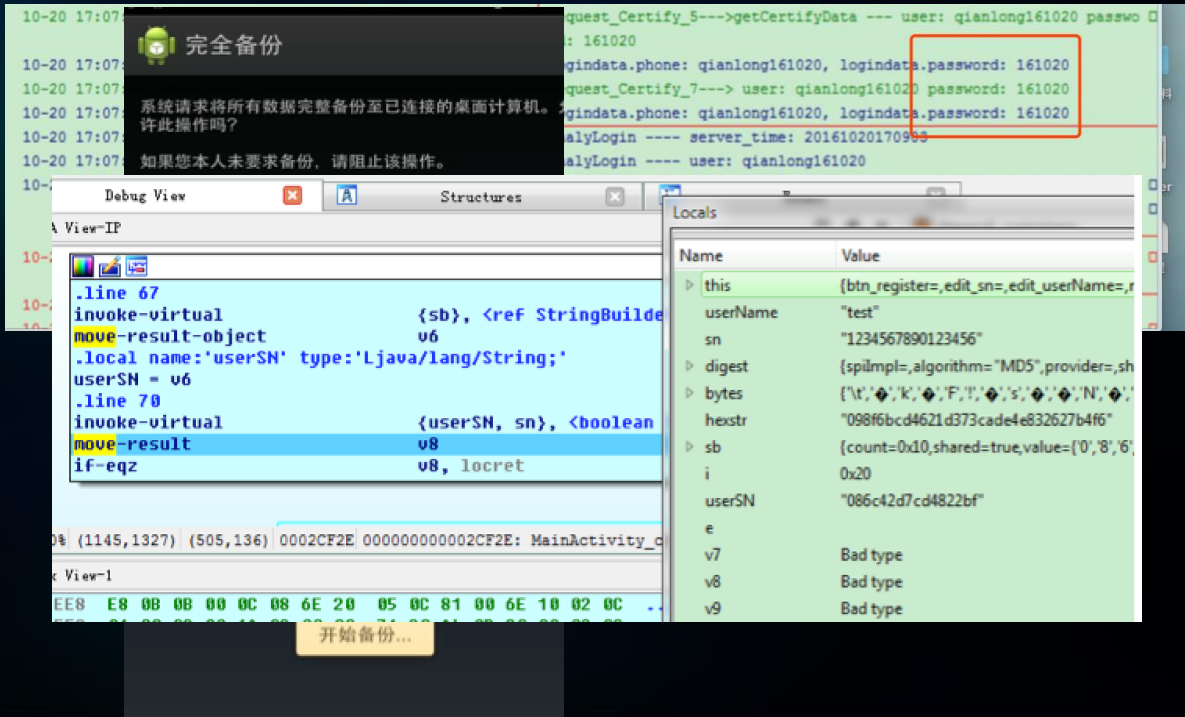
- 配置信息明文存储
- 日志输出明文敏感数据
- 数据传输直传直入
- 敏感信息本地存储

```
<int name= mSystem value= 5 />
<int name="mQSDM_4X" value="0" />
<int name="mProduct" value="256" />
<string name="mUser">qianlong161020</string>
<string name="mDeviceToken">357516116566245_192.168.30.71_de
<string name="mPassWord">161020</string>
/map>
```

10-20 17:07:31.893	1908	1..	qianlong....	qianlong161020	Request_Certify_5--->getCertifyData --- user: qianlong161020 passwo D rd: 161020
10-20 17:07:31.893	1908	1..	qianlong....	qianlong161020	logindata.phone: qianlong161020, logindata.password: 161020
10-20 17:07:32.363	1908	2..	qianlong....	qianlong161020	Request_Certify_7---> user: qianlong161020 password: 161020
10-20 17:07:32.363	1908	2..	qianlong....	qianlong161020	logindata.phone: qianlong161020, logindata.password: 161020
10-20 17:07:32.493	1908	2..	qianlong....	qianlong161020	AnalyLogin ---- server_time: 20161020170953
10-20 17:07:32.493	1908	2..	qianlong....	qianlong161020	AnalyLogin ---- user: qianlong161020
10-20 17:07:32.493	1908	2..	qianlong....	qianlong161020	Request53--->actionType = 1, user = qianlong161020, date = 0 0, cod D e = 01000001,02399001, version = V3.18 B001(20160818), platform = 5 D , product = 256, qsdm = 0
10-20 17:07:32.603	1908	1..	qianlong....	System...	MSG_UPDATE_DATA--->mMyApp.mUser = qianlong161020, mMyApp.mPassWord D = 161020
10-20 17:07:32.673	1908	1..	qianlong....	System...	qianlong161020-161020
10-20 17:07:33.643	1908	2..	qianlong....	qianlong161020	1. Request53--->actionType = 1, user = qianlong161020, date = 0 0, cod D

客户端缺陷

- 日志信息的保存
- 程序可被调试
- 任意数据备份
- 全局文件可读写



风险控制

- IP客观属性
- IP主动探测
- 历史行为辅助
- 风控规则
- 传统校验
-

C

怎么变的？

移动应用本身

- 用户

- 减少记忆内容
- 简化操作流程
- 增加认证因子
- 引入单点登录
- 内容输入判定
- 安全级别提醒
- 行为日志调取
- 敏感操作验证

- 后端

- 数据传输保护
- 后端多重验证
- 人机检测判定
- 权限划分清晰
- 数据安全存储
- 行为数据分析
- 运维体系建立
- 程序自我保护

风险控制





史蒂夫·乔布斯 - 献给疯狂而勇敢的人们

他们是一些与周围格格不入的人，是喜欢自由的人，是那些爱反抗的人，是那些爱惹麻烦的人；

他们以一种不同的方式看待世界。

他们不爱墨守成规，也不乐于接受现状。

你可以认同他们，也可以反对他们；可以赞美他们，也可以贬低他们，但是你唯一做不到的就是

忽略他们。因为是他们改变了世界，是他们推动了社会的前进。

也许有些人视他们为疯子，可我们视他们为天才。

因为真正改变了这个世界的，正是那些疯狂到认为自己能够改变世界的人。



THANKS!